



PHÁT HIỆN TẤN CÔNG INSIDER THREAT

Sử dụng Elastic SIEM · Sysmon · MITRE ATT&CK

Sinh viên: **Võ Quốc Huy**

MSSV: N23DCAT03 | Lớp: D23CQAT01-N

Học viện Công nghệ Bưu chính Viễn thông

An toàn thông tin · Blue Team · SOC · Detection Engineering



NỘI DUNG TRÌNH BÀY

Agenda — Cấu trúc bài thuyết trình



01

Tổng quan Insider Threat & Kỹ thuật tấn công



02

Kiến trúc hệ thống & Pipeline Log



03

Kịch bản tấn công & Kill Chain 6 Phase



04

Phân tích chi tiết từng Phase (EID + Alert)



05

Bảng Mapping MITRE ATT&CK



06

Detection Rules & Correlation Rule (EQL)



07

Demo & Kết quả kiểm thử



08

Kết luận & Bài học rút ra

INSIDER THREAT LÀ GÌ?

Mối đe dọa từ nội bộ — Nguy hiểm nhất, khó phát hiện nhất

>30%

vi phạm dữ liệu liên quan đến insider

Định nghĩa

Người có quyền truy cập hợp lệ — nhân viên, contractor, cựu nhân viên — gây hại từ bên trong tổ chức.



Tại sao nguy hiểm?

- Có quyền truy cập hợp lệ → không cần exploit
- Biết rõ hạ tầng, dữ liệu nhạy cảm, quy trình
- Không dùng malware → bypass AV/EDR truyền thống
- Hành vi trông như hoạt động quản trị bình thường

Phân loại

Malicious Insider

Cố tình gây hại / Đánh cắp dữ liệu

Negligent Insider

Vô tình gây ra sự cố bảo mật

Compromised Insider

Tài khoản bị chiếm quyền từ bên ngoài

LOLBINS & POWERSHELL ABUSE

Living-off-the-Land — Tấn công không cần malware



Living-off-the-Land (LOLBins)

- Chỉ dùng công cụ sẵn có trong Windows
- Ký số bởi Microsoft → vượt qua whitelist
- Không cần tải malware → bypass AV
- PowerShell, cmd.exe, reg.exe, wevtutil.exe
- Hành vi như quản trị bình thường



PowerShell Abuse

- -ExecutionPolicy Bypass → bỏ qua policy
- -WindowStyle Hidden → ẩn cửa sổ
- -EncodedCommand → mã hóa Base64
- Invoke-WebRequest → kết nối mạng
- Thao tác Registry, xóa file từ xa

Ví dụ lệnh tấn công:

```
powershell.exe -ExecutionPolicy Bypass -WindowStyle Hidden -EncodedCommand <base64_payload>
```



Detection Engineering

Thiết kế & xây dựng detection rules nhằm phát hiện hành vi bất thường. Cân bằng sensitivity vs false positive rate. Dùng MITRE ATT&CK làm nền tảng.

KIẾN TRÚC HỆ THỐNG

Windows Endpoint → Sysmon → Elastic Agent → Elasticsearch → Kibana SIEM → Alert

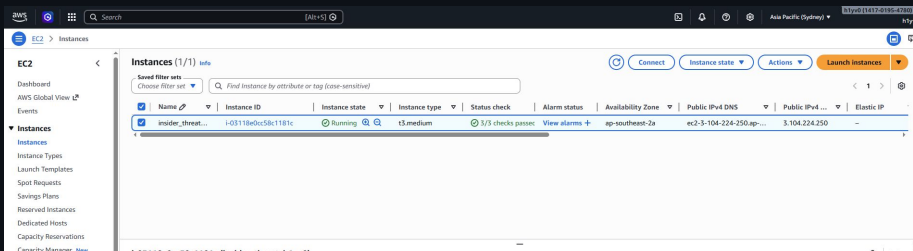


ALERT GENERATED

severity: critical | risk_score: 99 | MITRE tags | host.name + user.name | → SOC Investigation

Môi trường Lab:

AWS EC2 (Insider Endpoint) → HTTPS → Windows 10 Local (Elastic SIEM)



PIPELINE LOG — LUỒNG DỮ LIỆU

Sysmon EID → Elastic Agent → Elasticsearch → EQL Detection → Alert



**Windows
Endpoint**

Hành động insider



Sysmon

EID 1/3/11/13/23



Event Log

Sysmon/Operational



Elastic Agent

ECS Normalize
HTTPS/TLS



Elasticsearch

Data Stream
Index



EQL Rule

Every 5 minutes



ALERT

risk_score
severity

ECS Field Mapping — Sysmon → Elastic

Sysmon Field	ECS Field	Ý nghĩa
CommandLine	process.command_line	Dòng lệnh đầy đủ
Image	process.executable	Đường dẫn tiến trình
TargetFilename	file.path	Đường dẫn file (EID 11, 23)
TargetObject	registry.path	Registry key (EID 13)
DestinationIp	destination.ip	IP kết nối (EID 3)

KỊCH BẢN TẤN CÔNG INSIDER THREAT

Nhân viên rời công ty — Đánh cắp dữ liệu không để lại dấu vết



HỒ SƠ Insider

- Người dùng: ituser (standard account)
- Không có quyền admin
- Tài khoản Windows hợp lệ
- Không dùng exploit / malware
- Chỉ dùng PowerShell & LOLBins



Mục tiêu

- Đánh cắp source code & tài liệu nhạy cảm
- Thiết lập backdoor để quay lại sau
- Gửi dữ liệu ra ngoài qua HTTP
- Xóa bằng chứng sau khi exfiltration

Chuỗi Kill Chain



Điểm mấu chốt:

Toàn bộ 6 phase xảy ra từ CÙNG 1 user, CÙNG 1 host, trong 2 giờ → Correlation rule phát hiện với risk_score = 99 (CRITICAL)

Mỗi phase chuẩn bị điều kiện cho phase tiếp theo

[illegible]

EXECUTION

T1059.001 | EID 1

DISCOVERY

T1083 | EID 1

COLLECTION

T1560.001 | EID 11

PERSISTENCE

T1547.001 | EID 13

EXFILTRATION

T1041 | EID 3

IMPACT

T1070.004 | EID 23

PHASE 1 — EXECUTION

T1059.001 · PowerShell Bypass · Sysmon EID 1

PHASE 1

T1059.001

EID 1

Kỹ thuật tấn công

- -ExecutionPolicy Bypass → bỏ qua policy
- -WindowStyle Hidden → ẩn cửa sổ console
- -EncodedCommand → mã hóa Base64
- Script từ C:\Users\Public\ (staging location)
- Không cần quyền admin

EQL Detection Rule

```
process where event.type == "start"
and process.name like~ "powershell.exe"
and (
  cmd_line like~ "*-ExecutionPolicy Bypass*"
or cmd_line like~ "*-EncodedCommand*"
or cmd_line like~ "*-windowstyle hidden*"
)
and not process.parent.name like~ "msiexec.exe"
```

The screenshot shows the Microsoft Security Center console. The left sidebar contains navigation options: Security, Rules, Alerts, Attack discovery, Findings, and Data. The main content area is titled 'PHASE 1 - PowerShell Execution - Baseline'. It includes a description of the rule, its severity (Medium), risk score (50), and MITRE ATT&CK coverage (T1059.001). The 'Definition' tab is selected, showing the EQL query and the rule's index patterns.

PHASE 1 - PowerShell Execution - Baseline

Created by: Microsoft Defender for Cloud | Last updated: Apr 9, 2024 | 10:15:16 AM

Last response: succeeded at Apr 9, 2024 10:15:16 AM | Notify when alerts generated

About

Description
PowerShell Execution - Baseline

Severity
Medium

Risk score
50

MITRE ATT&CK
Execution (TA0002) | Command and Scripting Interpreter (T1059)

Definition

Index patterns
log-windows.system.operations.*

Custom query
event.code = 1 AND process.name = "powershell.exe"

Custom query language
EQL

Rule type
Query

Timeline template
None

The screenshot shows the Microsoft Security Center console. The left sidebar contains navigation options: Security, Rules, Alerts, Attack discovery, Findings, and Data. The main content area is titled 'PHASE 1 - PowerShell Execution - Baseline'. It includes a description of the rule, its severity (High), risk score (45), and MITRE ATT&CK coverage (T1059.001). The 'Definition' tab is selected, showing the EQL query and the rule's index patterns.

PHASE 1 - PowerShell Execution - Baseline

Created by: Microsoft Defender for Cloud | Last updated: Apr 9, 2024 10:15:16 AM

Last response: succeeded at Apr 9, 2024 10:15:16 AM | Notify when alerts generated

About

Description
Detects PowerShell launched with bypass flags commonly used by insiders and attackers. Focuses on suspicious ExecutionPolicy bypasses, encoded commands, and hidden window execution. Based on Sysmon process creation telemetry.

Severity
High

Risk score
45

MITRE ATT&CK
Execution (TA0002) | Command and Scripting Interpreter (T1059)

Max alerts per run
100

Definition

Index patterns
log-windows.system.operations.*

EQL query
process where event.type == "start" and process.name like~ "powershell.exe" and (cmd_line like~ "*-ExecutionPolicy Bypass*" or process.command_line like~ "-EncodedCommand*" or process.parent.name like~ "msiexec.exe") and not process.parent.name like~ "powershell.exe"

PHASE 1 — KẾT QUẢ KIỂM THỬ

Test 1.1: ExecutionPolicy Bypass · Test 1.2: EncodedCommand

```
PS C:\Windows\system32> get-Service Sysmon4

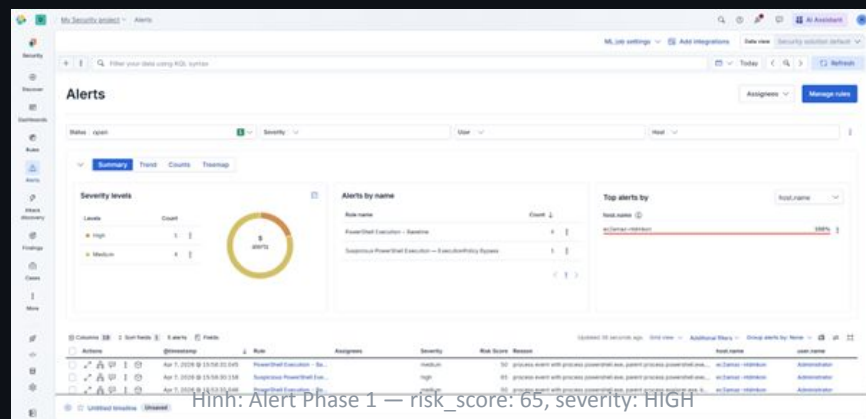
Status Name      DisplayName
-----
Running Sysmon4   Sysmon4

PS C:\Windows\system32> powershell.exe -ExecutionPolicy Bypass -NoProfile -Command "Write-Host 'TEST_PHASE1_EXEC_BYPASS'"
TEST_PHASE1_EXEC_BYPASS
PS C:\Windows\system32> Get-WinEvent -LogName "Microsoft-Windows-Sysmon/Operational" -MaxEvents 20 |
>> Where-Object { $_.Id -eq 1 }

ProviderName: Microsoft-Windows-Sysmon

TimeCreated      Id LevelDisplayName Message
-----
4/7/2026 9:00:25 AM 1 Information Process Create:...
4/7/2026 9:00:25 AM 1 Information Process Create:...
4/7/2026 9:00:25 AM 1 Information Process Create:...
4/7/2026 9:00:24 AM 1 Information Process Create:...
4/7/2026 9:00:24 AM 1 Information Process Create:...
4/7/2026 9:00:24 AM 1 Information Process Create:...
4/7/2026 9:00:22 AM 1 Information Process Create:...
4/7/2026 9:00:22 AM 1 Information Process Create:...
4/7/2026 9:00:22 AM 1 Information Process Create:...
4/7/2026 9:00:21 AM 1 Information Process Create:...
4/7/2026 9:00:08 AM 1 Information Process Create:...
4/7/2026 9:00:08 AM 1 Information Process Create:...
```

Hình: Thực thi lệnh bypass & log Sysmon EID 1



Hình: Alert Phase 1 — risk_score: 65, severity: HIGH

Lệnh kiểm thử

Test 1.1

```
powershell.exe -ExecutionPolicy Bypass -NoProfile -Command "Write-Host 'TEST_PHASE1'"
```

Test 1.2

```
$enc = [Convert]::ToBase64String([Text.Encoding]::Unicode.GetBytes("Write-Host 'test'")); powershell.exe -EncodedCommand $enc
```

PHASE 2 — DISCOVERY

T1083 File & Directory Discovery · T1087.001 Account Discovery · EID 1

PHASE 2

T1083 / T1087.001

EID 1

Hành vi trình sát

- Get-ChildItem -Recurse → liệt kê file nhạy cảm
- -Include *.docx, *.xlsx, *.pdf → targeted recon
- whoami /all → xác định quyền hạn
- net user / net localgroup → account discovery
- ipconfig /all → thông tin mạng

EQL Rule

```
process where event.type == "start"
and process.name like~ "powershell.exe"
and cmd_line like~ "*Get-ChildItem*"
and cmd_line like~ "*-Recurse*"
and (
  cmd_line like~ "*C:\\Users\\*"
  or cmd_line like~ "*C:\\Projects*"
)
and NOT parent.name like~ "explorer.exe"
```

The screenshot shows the 'Rules' page in the Microsoft Security Sentinel console. The selected rule is 'Discovery - PowerShell Enumeration (Simple)', which is currently disabled. The rule is categorized under 'Detection rules (SIEM)' and 'Discovery - PowerShe'. The 'About' section provides details: it detects PowerShell directory enumeration using Get-ChildItem, has a severity of 'Low', a risk score of '25', and is associated with MITRE ATTACK® T1083 (File and Directory Discovery). The 'Definition' section shows the index pattern 'logs-windows.system_operational', a custom query using KQL to filter for 'Get-ChildItem' events, and a rule type of 'Query'.

The screenshot shows the 'Alerts' page in the Microsoft Security Sentinel console. It displays a single alert with the status 'open' and severity 'Low'. The alert is titled 'Discovery - PowerShell Enumeration (Simple)'. The 'Severity levels' section shows a gauge for 'Low' severity with a count of 1. The 'Alerts by name' section shows a table with one entry: 'Discovery - PowerShell Enumeration (Simple)' with a count of 1. The 'Top alerts by' section shows a bar chart for 'e2d2a2e2-03b0-4b10-b010-000000000000' with a 100% score.

PHASE 2 — KẾT QUẢ KIỂM THỬ

Scripted discovery chain — Nguy hiểm nhất khi PS spawn nhiều recon tools

The image shows a Windows Task Manager window displaying the details of a PowerShell process. The process is named "PowerShell" and is running as a user administrator. The command line shows the process is running with the command "powershell.exe -ExecutionPolicy Bypass -Command 'Get-Childitem C:\Projects -Recurse | Select-Object FullName, Length, LastWriteTime'". The process is running on a Windows 10 system.

Below the Task Manager window, a Windows Security alert is displayed. The alert is titled "Alerts" and shows a severity level of "High". The alert message states: "A PowerShell process was detected running with the command 'powershell.exe -ExecutionPolicy Bypass -Command 'Get-Childitem C:\Projects -Recurse | Select-Object FullName, Length, LastWriteTime''. This command is used to recursively enumerate files and directories in a specified path, which is a common technique used by attackers to gather information about a system." The alert is dated 4/7/2024 at 9:28:02 AM.

The image shows a Microsoft Security Sentinel alert. The alert is titled "PowerShell Sensitive Directory Enumeration — Discovery Phase". The alert is dated 4/7/2024 at 9:28:02 AM. The alert message states: "Detects recursive directory enumeration via PowerShell targeting sensitive paths such as user directories, project folders, and document locations. This behavior is commonly associated with insider threat reconnaissance prior to data collection. The rule focuses on PowerShell cmdlets used with recursive parameters and sensitive directory patterns. Maps to MITRE ATT&CK T1053 File and Directory Discovery. This signal may have medium false positives when used standalone and is most effective when correlated with execution and collection phases." The alert is assigned to a user named "Administrator" and has a risk score of "Medium".

Scripted Discovery Chain:

```
powershell.exe -ExecutionPolicy Bypass -Command @"  
whoami  
net user  
ipconfig /all  
Get-Childitem C:\Projects -Recurse  
"@  
# → alert tăng thêm với risk_score cao hơn
```

PHASE 3 — COLLECTION

T1560.001 Archive via Utility · T1074.001 Local Data Staging · EID 1 + EID 11

PHASE 3

T1560.001 / T1074.001

EID 1 + EID 11

Thu thập dữ liệu

- Compress-Archive → nén dữ liệu thành .zip
- Staging path: C:\Users\Public\
(world-writable)
- Giảm kích thước để tăng tốc exfiltration
- EID 1 = command | EID 11 = file được tạo
- Mini-sequence: cả 2 phải có trong 2 phút

Mini-Sequence Rule (EQL)

```
sequence by host.name, user.name
with maxspan=2m
[process where
  cmd_line like~ "*Compress-Archive*"
  and cmd_line like~ "*Public*"
]
[file where
  file.extension in ("zip","7z","rar")
  and file.path like~ "*\\Public\\*"
]
```

The screenshot shows the MITRE ATT&CK framework interface. The left sidebar contains navigation links: Rules, Techniques, TTPs, and Tools. The main content area displays the 'PHASE 3 - Data Staging via PowerShell Archive' rule. The 'About' tab is active, showing a description of the rule, its severity (High), and its max alert per run (100). The 'Definition' tab is also visible, showing the EQL query used for the rule.

PHASE 3 - Data Staging via PowerShell Archive — Collection Phase

Created by: MITRE ATT&CK on 12/20/2016 10:01:00 AM. Updated by: MITRE ATT&CK on 12/20/2016 10:01:00 AM.

Link to rule: [https://attack.mitre.org/rule/T1560/001](#)

Severity: High

Max alerts per run: 100

Definition

EQL query

```
log analytics event where
  cmd_line like~ "*Compress-Archive*"
  and cmd_line like~ "*Public*"
  and file.extension in ("zip","7z","rar")
  and file.path like~ "*\\Public\\*"
```

The screenshot shows a Windows PowerShell terminal window. The user has executed the 'mkdir C:\Temp' command, which has created the directory. The output shows the directory path and the creation time. The user has then executed the 'powershell.exe -ExecutionPolicy Bypass -Command "Compress-Archive -Path C:\Projects -DestinationPath C:\Temp\backup_data.zip -Force"' command, which has compressed the contents of the 'C:\Projects' directory into a zip file named 'backup_data.zip' in the 'C:\Temp' directory. The output shows the command execution details and the file path.

Directory: C:\

Mode	LastWriteTime	Length	Name
d----	4/7/2026 10:09 AM		Temp

```
PS C:\Windows\system32> powershell.exe -ExecutionPolicy Bypass -Command "Compress-Archive -Path C:\Projects -DestinationPath C:\Temp\backup_data.zip -Force"
```

```
PS C:\Windows\system32> Test-Path C:\Temp\backup_data.zip
True
```

```
PS C:\Windows\system32> |
```

PHASE 3 — STAGING & KẾT QUẢ

File zip tạo tại C:\Users\Public\ + Alert High (risk_score: 70)

```
PS C:\Windows\system32> powershell.exe -ExecutionPolicy Bypass -Command "Compress-Archive -Path C:\Projects -DestinationPath C:\Users\Public\secret.zip -Force"
PS C:\Windows\system32> Test-Path "C:\Users\Public\secret.zip"
True
PS C:\Windows\system32>
```

```
PS C:\Windows\system32> mkdir C:\Temp
Directory: C:\

Mode                LastWriteTime         Length Name
----                -
d-----          4/7/2026 10:09 AM                 Temp

PS C:\Windows\system32> powershell.exe -ExecutionPolicy Bypass -Command "Compress-Archive -Path C:\Projects -DestinationPath C:\Temp\backup_data.zip -Force"
PS C:\Windows\system32> Test-Path C:\Temp\backup_data.zip
True
PS C:\Windows\system32> |
```

my-security-project-f181e0kbus-central1.gcp.elastic.cloud/app/security/alerts/timeline=(activeTabquery.sOpenIf.query(expression=%27%27&kind=query)&timerange=(global.\$linkTo.\$timeline).timerange(from:%272025-04-05T17:00:00.000...)

Ứng dụng: social media, công cụ, trang học tập, mail/drive/ics, CTF, passive reconnaissance, action hand on cy..., TTCS, Công nghệ Phần M...

My Security project Alerts

Security

Discover

Dashboards

Rules

Alerts

Attack discovery

Findings

Cases

Filter your data using KQL syntax

Alerts

Status: open Severity: User:

Summary

Trend

Counts

Treemap

Severity levels

Levels	Count
High	3
Medium	10
Low	6

10 alerts

Alerts by name

Rule name	Count ↓
PowerShell Execution - Baseline	7
Discovery - PowerShell Enumeration (Simple)	6
PowerShell Sensitive Directory Enumeration — Discovery ...	3
Data Staging via PowerShell Archive — Collection Phase	2

Data Staging via PowerShell Archive — Collection Phase

Created by: 3187684407 on Apr 7, 2026 @ 16:51:15.868

Updated by: 3187684407 on Apr 7, 2026 @ 17:06:51.605

About

Detects Compress-Archive or archive creation in staging directories (Temp, Public, AppData). Correlates PowerShell execution with file creation to confirm data staging. Maps to MITRE ATT&CK T1560.001 and T1074.001.

Severity

High

Risk score

70

Max alerts per run

100

Definition

Schedule

PHASE 4 — PERSISTENCE

T1547.001 Registry Run Keys · EID 13 Registry Value Set · risk_score: 80

PHASE 4

T1547.001

EID 13

Cơ chế Persistence

- Registry Run Key → tự chạy khi login
- HKCU không cần quyền admin
- Tên giả: UpdateSvc, WindowsHelper
- EID 13: ghi nhận giá trị registry bị thay đổi
- KEY: kiểm tra NỘI DUNG value, không chỉ path

EQL Rule (Registry Data Mutation)

```
registry where event.type == "change"
and registry.path like~
    "*\\CurrentVersion\\Run\\"
and registry.data.strings like~ (
    "*powershell*", "*cmd.exe*",
    "*.ps1*", "*.bat*", "*.vbs*"
)
and NOT data.strings like~
    "*\\Program Files\\"
```

The screenshot displays the MITRE ATT&CK framework interface. The left sidebar shows the navigation menu with 'Rules' selected. The main content area is titled 'PHASE 4 - Persistence - Registry Run Key Script Interpreter'. It includes a description of the rule, its severity (High), and its risk score (80). The 'About' section provides details about the rule's purpose and the MITRE ATT&CK framework. The 'Definition' section shows the EQL query used to detect the rule, which checks for registry value mutations in the 'Run' key of the 'CurrentVersion' path, specifically looking for strings like powershell, cmd.exe, ps1, bat, or vbs.

The screenshot displays the MITRE ATT&CK framework interface, specifically the 'Alerts' section. The left sidebar shows the navigation menu with 'Alerts' selected. The main content area is titled 'Alerts' and shows a summary of the alerts. A donut chart indicates that there is 1 alert. The 'Alerts by name' section lists the alert, which is 'PHASE 4 - Persistence - Registry Run Key Script Interpreter'. The right sidebar shows the 'About' section for the alert, which includes a description of the rule and its severity (High).

PHASE 4 — KIỂM THỬ & FALSE POSITIVE

reg.exe / Set-ItemProperty / RunOnce — Rule phân biệt bằng nội dung value

```
Administrator: Windows PowerShell
The operation completed successfully.
PS C:\Windows\system32> Get-WinEvent -LogName "Microsoft-Windows-Sysmon/Operational" -MaxEvents 20 |
>> Where-Object { $_.Id -eq 13 -and $_.Message -like "*Run*" } |
>> Select-Object TimeCreated, @{N="Details";E=[($_.Message -split "`n" | Where-Object { $_ -like "*Details*"})[0]]} |
>> Format-List

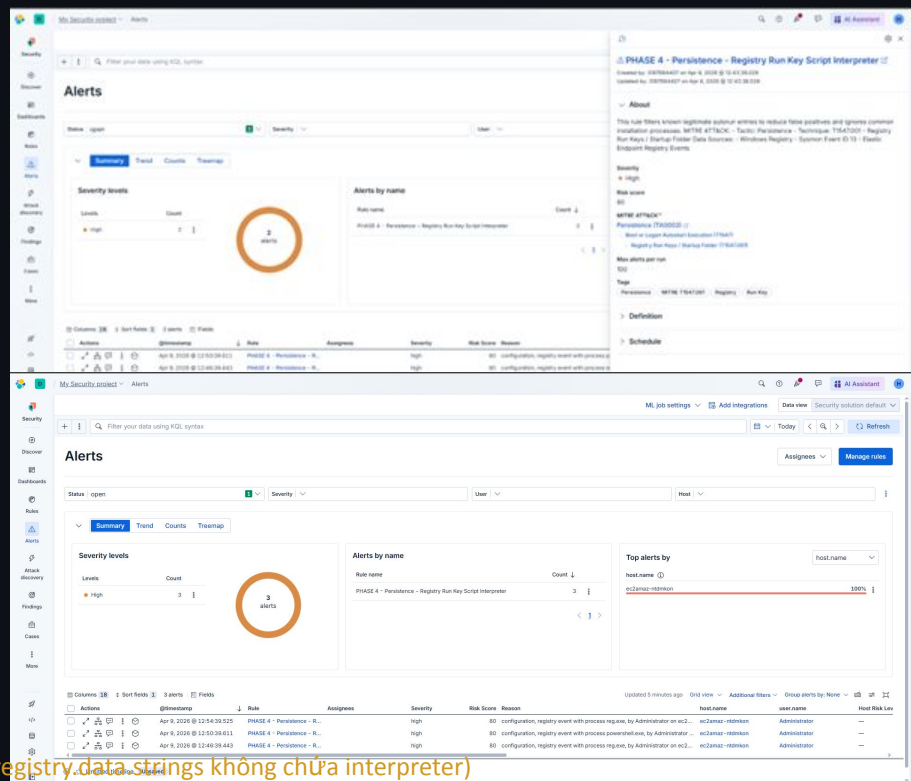
TimeCreated : 4/9/2026 5:46:14 AM
Details      : D

TimeCreated : 4/9/2026 5:45:54 AM
Details      : D

PS C:\Windows\system32> Get-WinEvent -LogName "Microsoft-Windows-Sysmon/Operational" |
>> Where-Object { $_.Id -eq 13 } |
>> Select-Object -First 1 -ExpandProperty Message
Registry value set:
RuleName: T1060,RunKey
EventType: SetValue
UtcTime: 2026-04-09 05:46:14.255

PS C:\Windows\system32> reg add "HKCU\Software\Microsoft\Windows\CurrentVersion\Run" /v "TestLegitApp" /t REG_SZ /d "C:\Program Files\TestApp\testapp.exe" /f

The operation completed successfully.
PS C:\Windows\system32> Get-WinEvent -LogName "Microsoft-Windows-Sysmon/Operational" |
>> Where-Object { $_.Id -eq 13 and $_.Message -match "TestLegitApp" } |
>> Select-Object -First 1 -ExpandProperty Message
Registry value set:
RuleName: T1060,RunKey
EventType: SetValue
UtcTime: 2026-04-09 06:00:03.202
ProcessGuid: {e4b7648b-488b-69d7-beb1-680000003f60}
ProcessId: 6184
Image: C:\Windows\system32\reg.exe
TargetObject: HKCU\Software\Microsoft\Windows\CurrentVersion\Run\TestLegitApp
Details: C:\Program Files\TestApp\testapp.exe
User: EC2JAMZ-WIDRMON\Administrator
PS C:\Windows\system32>
```



FALSE POSITIVE: Run key trở đến .exe → Sysmon log có nhưng KHÔNG có Alert (registry.data.strings không chứa interpreter)

PHASE 5 — EXFILTRATION

T1041 Over C2 Channel · T1071.001 Web Protocols · EID 3 Network Connection

PHASE 5

T1041 / T1071.001

EID 3

Đánh cắp dữ liệu qua HTTP

- Invoke-WebRequest → kết nối HTTP/HTTPS
- iwr / wget / curl (alias) → bypass cmdlet check
- .NET WebClient → bypass PS detection
- Rule dùng EID 3 (network event) → bypass-resistant
- Loại trừ IP nội bộ + domain Microsoft

EQL Rule (Network Event — Bypass-Resistant)

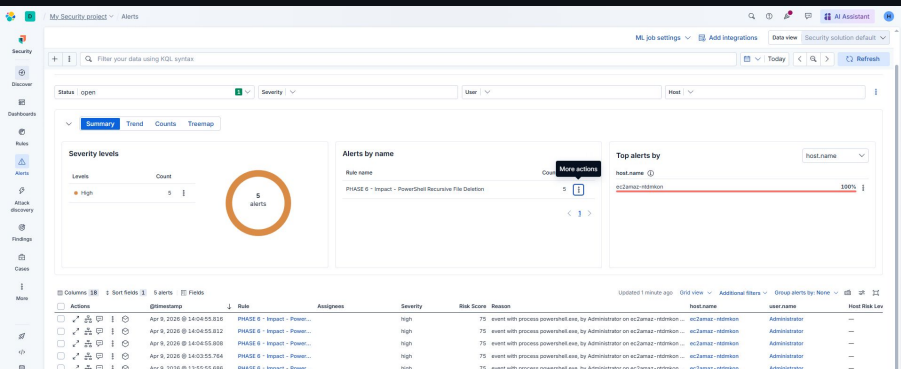
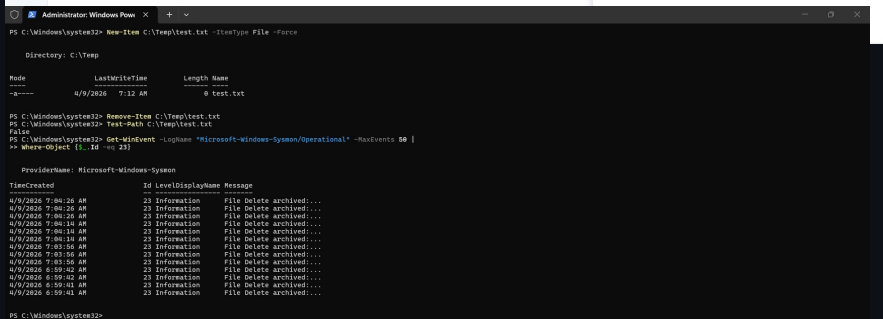
[illegible]

```
PS C:\Windows\system32> "C:\Windows\System0.exe" -c | findstr Network
At line 1 char 27
    ~~~~~
    ~~~~~
    ~~~~~
Unexpected token '-' in expression or statement.
+ CategoryInfo          : ParserError: (3 [1], ParentContainsErrorRecordException)
+ FullyQualifiedErrorId : UnexpectedToken

PS C:\Windows\system32> & "C:\Windows\System0.exe" -c | findstr Network

- Network connection:         enabled
CommandLine                   Filter: %s      value: 'C:\Windows\system32\svchost.exe -k LocalServiceNetworkRestricted -p Dhcp'
CommandLine                   Filter: %s      value: 'C:\Windows\system32\svchost.exe -k LocalServiceNetworkRestricted -p Location'
CommandLine                   Filter: %s      value: 'C:\Windows\system32\svchost.exe -k LocalServiceNetworkRestricted -p TimeServerSvc'
CommandLine                   Filter: %s      value: 'C:\Windows\system32\svchost.exe -k LocalServiceNetworkRestricted -p WUDFConfigSvc'
CommandLine                   Filter: %s      value: 'C:\Windows\system32\svchost.exe -k LocalServiceNetworkRestricted -p BTSService'
CommandLine                   Filter: %s      value: 'C:\Windows\system32\svchost.exe -k LocalSystemNetworkRestricted -p RchService'
CommandLine                   Filter: %s      value: 'C:\Windows\system32\svchost.exe -k LocalServiceNetworkRestricted'
CommandLine                   Filter: %s      value: 'C:\Windows\system32\svchost.exe -k LocalServiceNetwork'
CommandLine                   Filter: %s      value: 'C:\Windows\system32\svchost.exe -k LocalSystemNetworkRestricted -p WPDemoEnum'
CommandLine                   Filter: %s      value: 'C:\Windows\system32\svchost.exe -k LocalSystemNetworkRestricted -p xhci'
CommandLine                   Filter: %s      value: 'C:\Windows\system32\svchost.exe -k LocalSystemNetworkRestricted -p DeviceAssociationServ
```


Sysmon EID 23 phải bật thủ công — quan trọng nhất trong Phase 6



```
<FileDelete onmatch="include">
  <TargetFilename condition="contains">
    C:\Projects
  </TargetFilename>
  <TargetFilename condition="end with">
    .docx
  </TargetFilename>
</FileDelete>
# sysmon64.exe -c sysmonconfig.xml
```

BẢNG MAPPING MITRE ATT&CK

6 Phase → 10+ Techniques → Sysmon Event IDs

Phase	Tactic	Technique	Sub-Technique	EID	Log Source
1 – Execution	TA0002 Execution	T1059	T1059.001 PowerShell	EID 1	Sysmon Process
2 – Discovery	TA0007 Discovery	T1083	—	EID 1	Sysmon Process
2 – Discovery	TA0007 Discovery	T1087	T1087.001 Local	EID 1	Sysmon Process
3 – Collection	TA0009 Collection	T1560	T1560.001 Utility	EID 1+11	Sysmon Proc+File
3 – Collection	TA0009 Collection	T1074	T1074.001 Local	EID 11	Sysmon File
4 – Persistence	TA0003 Persistence	T1547	T1547.001 Run Key	EID 13	Sysmon Registry
5 – Exfiltration	TA0010 Exfiltration	T1041	—	EID 3	Sysmon Network
5 – Exfil / C&C	TA0011 C&C	T1071	T1071.001 Web	EID 3	Sysmon Network
6 – Def.Evasion	TA0005 Def.Evasion	T1070	T1070.004 File Deletion	EID 23	Sysmon File Del
6 – Impact	TA0040 Impact	T1485	Data Destruction	EID 23	Sysmon File Del

DETECTION RULES — TỔ CHỨC VÀ LOGIC

6 Phase rules + 1 Correlation rule — Thiết kế giảm false positive

P1 PS ExecutionPolicy Bypass

High 65

process.command_line contains bypass flags

P2 Sensitive Dir Enumeration

Med 45

Get-ChildItem -Recurse + sensitive path

P3 Archive in Staging Path

High 70

Sequence: cmd EID1 + file EID11 within 2m

P4 Registry Run Key Mutation

High 80

registry.data.strings contains interpreter

P5 PS Outbound HTTP

High 78

network EID3 from PS.exe to external IP

P6 Recursive File Deletion

High 72

Sequence: Remove-Item -Recurse + EID23

CORRELATION RULE — FULL KILL CHAIN

EQL Sequence · by host.name, user.name · maxspan=2h · risk_score=99 CRITICAL

Tại sao sequence?

6 events phải theo đúng thứ tự — không thể exfil trước khi collect. Thứ tự ngẫu nhiên gần như không xảy ra.

Tại sao maxspan=2h?

30 phút quá ngắn, 24 giờ quá rộng. 2 giờ = 1 session làm việc thực tế của insider.

host.name + user.name?

Tránh match chéo giữa user khác nhau trên cùng máy hoặc cùng user trên máy khác.

sequence by host.name, user.name with maxspan=2h

```
/* PHASE 1: EXECUTION */
[process where cmd_line like~ "*-ExecutionPolicy Bypass*"]

/* PHASE 2: DISCOVERY */
[process where cmd_line like~ "*Get-ChildItem*" and cmd_line like~ "*-Recurse*"]

/* PHASE 3: COLLECTION */
[process where cmd_line like~ "*Compress-Archive*"]

/* PHASE 4: PERSISTENCE */
[registry where event.type == "change" and reg.path like~ "*\\Run\\"
  and reg.data.strings like~ ("powershell*", "*.ps1")]

/* PHASE 5: EXFILTRATION */
[network where process.name == "powershell.exe" and dest.port in (80,443,8080)]

/* PHASE 6: DEFENSE EVASION */
[process where cmd_line like~ "*Remove-Item*" and cmd_line like~ "*-Recurse*"]
```

CORRELATION — TẠI SAO GIẢM FALSE POSITIVE?

Single rule vs Correlation rule — Tại sao sequence hiệu quả hơn



Single Rules (Nguy cơ FP cao)

- Phase 1 (PS bypass): ~200-500 alerts/ngày
- Phase 2 (Get-ChildItem): ~1000+ alerts/ngày
- Phase 5 (HTTP từ PS): ~100-300 alerts/ngày
- SOC analyst bị overwhelmed
- True positive bị chìm trong noise
- Alert fatigue → bỏ lỡ real attack



Correlation Rule (FP gần bằng 0)

- Yêu cầu đủ 6 events → xác suất ngẫu nhiên ≈ 0
- Cùng user + cùng host + đúng thứ tự + 2h
- ~1-5 CRITICAL alerts/ngày (chỉ real attack)
- SOC analyst tập trung vào điều tra
- Mỗi alert = 1 confirmed incident
- risk_score: 99 → P1 immediate response



Kết quả: 2000+ alerts/ngày từ single rules → 5 CRITICAL alerts/ngày từ correlation rule

DEMO — KẾT QUẢ KIỂM THỬ

Full Kill Chain Simulation — Kibana Alert Timeline

```
Administrator: Windows Pow...
PS C:\Windows\system32> powershell.exe -ExecutionPolicy Bypass -Command "Write-Host Phase1"
Phase1
PS C:\Windows\system32> powershell.exe -ExecutionPolicy Bypass -Command "Get-Childitem C:\Projects -Recurse"
PS C:\Windows\system32> powershell.exe -ExecutionPolicy Bypass -Command "Compress-Archive -Path C:\Projects -DestinationPath C:\Users\Public\data.zip -Force"
PS C:\Windows\system32> reg add HKEY\Software\Microsoft\Windows\CurrentVersion\Run /v updater /t REG_SZ /d "powershell.exe -ExecutionPolicy Bypass -File C:\Users\Public\app\load.ps1" /f
The operation completed successfully.
PS C:\Windows\system32> powershell.exe -ExecutionPolicy Bypass -Command "Iex http://example.com -UseBasiParsing"

StatusCode      : 200
StatusDescription : OK
Content          : <doctype html>html lang=en">head<title>example Domain</title><meta name="viewport" content="width=device-width, initial-scale=1"><style>body{background:#eee;width:600px;margin:10px auto;font-family:
RawContent       : Transfer-Encoding: chunked
Connection: keep-alive
Allow: GET, HEAD
Age: 1927
CF-Cache-Status: HIT
CF-RAY: 6e9f03711cada932-SYD
Accept-Ranges: bytes
Content-Type: text/html
Date: ...
Expires: ...
Transfer-Encoding: chunked, [Connection, keep-alive], [Allow, GET, HEAD], [Age, 1927]...
Headers         : {}
InputFields     : {}
Links           : [{OuterHTML=<a href="https://iana.org/domains/example">Learn more</a>; tagName=a; href=https://iana.org/domains/example}]
Resource        : {}
RawContentLength: 528

PS C:\Windows\system32> powershell.exe -ExecutionPolicy Bypass -Command "Remove-Item C:\Projects\* -Recurse -Force"
PS C:\Windows\system32>
```

Chạy toàn bộ 6 phase trong 1 session

```
PS C:\Windows\system32> Get-WinEvent -LogName "Microsoft-Windows-Sysmon/Operational" |
>> Where-Object {$_.Id -eq 3} |
>> Select-Object -First 3
```

ProviderName: Microsoft-Windows-Sysmon			
TimeCreated	Id	Level	DisplayName Message
4/9/2026 6:27:38 AM	3	Information	Network connection detected:...
4/9/2026 6:22:00 AM	3	Information	Network connection detected:...
4/9/2026 6:18:27 AM	3	Information	Network connection detected:...

```
PS C:\Windows\system32> Get-WinEvent -LogName "Microsoft-Windows-Sysmon/Operational" |
>> Where-Object {$_.Id -eq 1 -and $_.Message -match "Remove-Item"} |
>> Select -First 1
```

ProviderName: Microsoft-Windows-Sysmon			
TimeCreated	Id	Level	DisplayName Message
4/9/2026 7:34:05 AM	1	Information	Process Create:...

```
PS C:\Windows\system32>
```

```
Administrator: Windows Pow...
PS C:\Windows\system32> Get-WinEvent -LogName "Microsoft-Windows-Sysmon/Operational" |
>> Where-Object {$_.Message -match "ExecutionPolicy"} |
>> Select -First 1

ProviderName: Microsoft-Windows-Sysmon
TimeCreated      Id LevelDisplayName Message
-----
4/9/2026 7:34:05 AM 1 Information Process Create:...

PS C:\Windows\system32> Get-WinEvent -LogName "Microsoft-Windows-Sysmon/Operational" |
>> Where-Object {$_.Message -match "Get-Childitem"} |
>> Select -First 1

ProviderName: Microsoft-Windows-Sysmon
TimeCreated      Id LevelDisplayName Message
-----
4/9/2026 7:33:06 AM 1 Information Process Create:...

PS C:\Windows\system32> Get-WinEvent -LogName "Microsoft-Windows-Sysmon/Operational" |
>> Where-Object {$_.Message -match "Compress-Archive"} |
>> Select -First 1

ProviderName: Microsoft-Windows-Sysmon
TimeCreated      Id LevelDisplayName Message
-----
4/9/2026 7:33:27 AM 1 Information Process Create:...

PS C:\Windows\system32> Get-WinEvent -LogName "Microsoft-Windows-Sysmon/Operational" |
>> Where-Object {$_.Id -eq 15 -and $_.Message -match "CurrentVersion\Run"} |
>> Select -First 1

ProviderName: Microsoft-Windows-Sysmon
TimeCreated      Id LevelDisplayName Message
-----
4/9/2026 6:08:43 AM 13 Information Registry Value Set:...
```

Tất cả 6 phase hoàn thành thành công

Correlation Rule EQL — sequence đầy đủ trong Kibana SIEM

KIẾN TRÚC DETECTION — 5 TẦNG

Data Collection → Transport → Storage → Detection → Response



Layer 1

Data Collection

Windows Endpoint → Sysmon EID 1/3/11/13/23 → Windows Event Log



Layer 2

Transport

Elastic Agent → ECS Normalization → HTTPS/TLS → Elasticsearch



Layer 3

Storage & Index

Elasticsearch → Data Stream → Index Mapping ECS → Query Ready



Layer 4

Detection Engine

Elastic SIEM → EQL Rules mỗi 5 phút → Match → Alert Document



Layer 5

Response

Kibana Dashboard → SOC Analyst Review → Investigate Timeline → Containment

KẾT LUẬN — BÀI HỌC RÚT RA

Detection Engineering · Sysmon · Correlation · MITRE ATT&CK

Detection Engineering



Rule tốt = hỏi 'tại sao bất thường?' không phải 'hành vi có xảy ra không?'. Cân bằng sensitivity vs FP rate.

MITRE ATT&CK



Ngôn ngữ chung của security community. Mapping technique → measurable coverage, không chỉ là checklist.

Sysmon Logging



EID 23 phải bật thủ công. Log quá nhiều = alert fatigue. Chiến lược lọc thông minh từ sysmonconfig.xml.

Insider Threat



LOLBins bypass AV/EDR truyền thống. Behavioral detection là hướng bắt buộc. Sysmon + SIEM là nền tảng.

KHÓ KHĂN & HƯỚNG PHÁT TRIỂN

Những thách thức gặp phải và roadmap cải thiện hệ thống



Khó khăn gặp phải

- Sysmon EID 23 không bật mặc định
- Index pattern mismatch → rule không sinh alert
- ECS field mapping cần verify thực tế
- Phase 2 (Discovery) FP cao → cần nhiều vòng tuning
- AWS Security Group giới hạn test Phase 5
- Elastic Agent version ảnh hưởng field normalization



Hướng Phát Triển

- User Behavior Analytics (UBA) + Elastic ML
- Mở rộng lateral movement detection
- SOAR automation — tự động response
- DNS monitoring (Sysmon EID 22)
- Asset criticality scoring trong risk engine
- Thêm UEBA cho insider baseline behavior

TỔNG KẾT — NHỮNG GÌ ĐẠT ĐƯỢC

Mục tiêu đồ án đã hoàn thành

Môi trường Lab



AWS EC2 + Windows 10 local ELK Stack — fully functional

6 Detection Rules (EQL)



Mỗi phase 1 rule — False positive được kiểm soát

Sysmon telemetry



5 Event IDs (1, 3, 11, 13, 23) được cấu hình đúng

Correlation Rule



Full sequence 6 phase · maxspan=2h · risk_score=99

Kill Chain simulation



6 phase hoàn chỉnh — đúng thứ tự, cùng user/host

MITRE ATT&CK Mapping



10+ techniques ánh xạ chính xác với EID và rules



XIN CẢM ƠN!

Insider Threat Detection · Elastic SIEM · Sysmon · MITRE ATT&CK

Sinh viên: **Võ Quốc Huy**

MSSV: N23DCAT03 | Lớp: D23CQAT01-N

Học viện Công nghệ Bưu chính Viễn thông

Khoa CNTT 2 · An toàn thông tin · 2025–2026



Câu hỏi & Thảo luận

Q & A